

Security Audit Report

Controls & Compliance Checklist — Botium Toys Inc.

Audit Type	Framework	Risk Score	Status
Internal IT Security Audit	NIST CSF	8 / 10 (High)	Completed

Project Overview

This activity is part of the Google Cybersecurity Certificate curriculum. As a cybersecurity analyst, I was tasked with conducting an internal IT security audit for Botium Toys — a small U.S. toy company with a growing online and international presence. The audit used the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) as its guiding structure, with a focus on assessing the company's current controls and compliance posture across three major frameworks: PCI DSS (payment card security), GDPR (EU data protection), and SOC (system and organisation controls).

The audit required reviewing the IT manager's scope, goals, and risk assessment report, cross-referencing identified assets and gaps against the control categories document, and completing a controls and compliance checklist with evidence-based Yes/No determinations and prioritised recommendations for the IT manager.

Company Background

Botium Toys is a small U.S. business that develops and sells toys from a single physical location that serves as its main office, storefront, and warehouse. The company's online presence has grown significantly, attracting customers in the U.S. and abroad. The IT department is under increasing pressure to support the online market while maintaining compliance and business continuity. The IT manager implemented the NIST CSF, established audit scope and goals, catalogued current assets, and completed a risk assessment before requesting this internal audit.

Audit Scope & Goals

Scope: The entire security program at Botium Toys. All assets assessed alongside internal processes and procedures related to controls and compliance best practices.

Goal: Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture.

Current Assets

The following assets are currently managed by the IT Department and were assessed during this audit:

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access and internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Risk Assessment Summary

Risk Score: 8 / 10 (High) — due to lack of controls and adherence to compliance best practices

Root Cause: Inadequate asset management; many controls not implemented; non-compliance with U.S. and international regulations

Key findings: All employees have access to internally stored data including cardholder data and PII/SPII; no encryption; no least privilege; no IDS; no disaster recovery; no backups; weak password policy; no centralised password management; no legacy system maintenance schedule

Controls & Compliance Checklist

The following checklists reflect the current state of Botium Toys' security controls and compliance posture, based on the risk assessment report. ✓ = in place, X = not in place.

Controls Assessment

Does Botium Toys currently have this control in place?

Administrative / Managerial Controls

Yes	No	Control
	X	Least Privilege — Not implemented. All employees have access to all internal data including cardholder data and PII/SPII.
	X	Disaster Recovery Plans — Not in place. No business continuity planning exists.
✓		Password Policies — A policy exists but requirements are nominal and below current minimum complexity standards.
	X	Separation of Duties — Not implemented. No role-based access restrictions are in place.

Technical Controls

Yes	No	Control
✓		Firewall — In place with an appropriately defined set of security rules.
	X	Intrusion Detection System (IDS) — Not installed. The IT department has not deployed an IDS.
	X	Backups — Not in place. No backups of critical data exist.
✓		Antivirus Software — Installed and monitored regularly by the IT department.
✓		Manual Monitoring, Maintenance & Intervention for Legacy Systems — Monitored and maintained, but no formal schedule or defined intervention methods.
	X	Encryption — Not in use. Customer credit card information is stored locally without encryption.
	X	Password Management System — No centralised system exists to enforce password policy requirements.

Physical / Operational Controls

Yes	No	Control
✓		Locks (offices, storefront, warehouse) — Sufficient locks are in place at all physical locations.
✓		Closed-Circuit Television (CCTV) Surveillance — Up-to-date CCTV surveillance is in place.

✓	Fire Detection / Prevention (fire alarm, sprinkler system) — Functioning fire detection and prevention systems are in place.
---	--

Compliance Checklist

Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best Practice
	X	Only authorized users have access to customers' credit card information. — NO: All employees have access to internally stored data, including cardholder data.
	X	Credit card information is stored, accepted, processed, and transmitted in a secure environment. — NO: No encryption is in use; data is stored locally without security controls.
	X	Data encryption procedures are implemented to secure credit card transaction touchpoints. — NO: Encryption is not currently used.
	X	Secure password management policies are adopted. — NO: Password policy is nominal; no centralised management system exists.

General Data Protection Regulation (GDPR)

Yes	No	Best Practice
	X	E.U. customers' data is kept private/secured. — NO: No encryption; broad internal access to all data including EU customer records.
✓		A plan is in place to notify E.U. customers within 72 hours if their data is compromised. — YES: The IT department has established this notification procedure.
	X	Data is properly classified and inventoried. — NO: Asset management is inadequate; no data classification system exists.
✓		Privacy policies, procedures, and processes are enforced to properly document and maintain data. — YES: Policies have been developed and are enforced among IT department members.

System and Organization Controls (SOC Type 1 / Type 2)

Yes	No	Best Practice
	X	User access policies are established. — NO: No least privilege or access control policies are implemented; all employees have broad access.

	X	Sensitive data (PII/SPII) is confidential/private. — NO: All employees can access PII/SPII; no encryption or access controls protect it.
✓		Data integrity ensures data is consistent, complete, accurate, and validated. — YES: The IT department has integrated controls to ensure data integrity.
✓		Data is available to individuals authorized to access it. — YES: The IT department has ensured availability of data.

Findings & Risk Analysis

Control / Compliance Gap	Risk Category	Severity	Compliance Framework(s) Affected
No least privilege / separation of duties	Access Control	Critical	PCI DSS, GDPR, SOC
No encryption for cardholder data	Confidentiality	Critical	PCI DSS, GDPR
No disaster recovery plans	Availability	High	SOC
No backups of critical data	Availability	High	SOC
No Intrusion Detection System	Detection	High	NIST CSF
No centralised password management	Authentication	High	PCI DSS
Nominal password policy	Authentication	Medium	PCI DSS, NIST CSF
No legacy system maintenance schedule	Operational	Medium	NIST CSF
No data classification/inventory	Governance	Medium	GDPR, SOC

Recommendations

The following recommendations are prioritised by severity for the IT manager to communicate to stakeholders:

- (CRITICAL) Implement least privilege and separation of duties immediately. All employees currently have access to cardholder data and PII/SPII. This is the

highest-priority finding as it violates PCI DSS Requirement 7, GDPR data minimisation principles, and SOC access control requirements simultaneously.

- (CRITICAL) Implement encryption for all customer credit card data at rest and in transit. Without encryption, the company is fully non-compliant with PCI DSS Requirements 3 and 4, and GDPR Article 32 (appropriate technical measures).
- (HIGH) Develop and test disaster recovery plans and establish regular data backups. The absence of DR plans and backups means a single ransomware attack or hardware failure could permanently destroy critical business and customer data with no recovery path.
- (HIGH) Deploy an Intrusion Detection System (IDS) to provide visibility into network threats. The existing firewall only blocks known-bad traffic; an IDS would detect anomalous traffic patterns and provide early warning of breaches in progress.
- (HIGH) Implement a centralised password management system that enforces strong password complexity requirements (minimum 8 characters, mixed case, numbers, special characters). The current nominal policy without enforcement is insufficient to prevent credential-based attacks.
- (MEDIUM) Establish a formal schedule and documented procedures for legacy system monitoring and intervention. Ad-hoc monitoring of end-of-life systems creates unpredictable risk windows.
- (MEDIUM) Implement a data classification and inventory system to meet GDPR data minimisation and SOC data governance requirements, and to support the NIST CSF Identify function.

Key Takeaways

- A risk score of 8/10 indicates a severely exposed security posture. The combination of no encryption, no access controls, no IDS, no backups, and no disaster recovery plans means a single successful attack could cause catastrophic damage to Botium Toys' data, reputation, and regulatory standing.
- Compliance and security are mutually reinforcing. Addressing the critical controls gaps (least privilege, encryption, password management) simultaneously resolves violations across multiple frameworks (PCI DSS, GDPR, SOC), maximising the return on each security investment.
- Physical security is a relative strength. Botium Toys has adequate locks, CCTV, and fire suppression in place — the most significant gaps are in the administrative/managerial and technical control categories, particularly around data access and confidentiality.
- The NIST CSF Identify function is the most critical immediate gap. Without proper asset classification and data inventory, the company cannot even determine the full scope of what data they hold, where it is, and who should have access to it — making all subsequent protective controls less effective.

- GDPR compliance carries significant financial risk. With a growing EU customer base, non-compliance with GDPR can result in fines of up to €20 million or 4% of global annual turnover — existential for a small business. The 72-hour breach notification plan is in place, but the underlying data security controls are not.

Skills Demonstrated

Audit Skills	Security Knowledge	Professional Competencies
Internal security audit conduct NIST CSF application Controls assessment Compliance gap analysis Risk prioritisation Evidence- based determination	PCI DSS requirements GDPR compliance obligations SOC framework Administrative/Technical/Physical controls Control types (preventive/detective/corrective) Defence-in-depth principles	Audit report writing Stakeholder recommendations Risk communication Regulatory landscape awareness Security posture assessment Framework- driven analysis

Conclusion

This internal audit revealed that Botium Toys has significant security and compliance gaps that pose a high risk (8/10) to its assets, operations, and regulatory standing. While the company has some foundational controls in place (firewall, antivirus, physical security, GDPR breach notification), the absence of encryption, access controls, backups, an IDS, and disaster recovery plans leaves it highly vulnerable to both external attacks and regulatory penalties.

The prioritised recommendations provided to the IT manager focus on the highest-severity gaps first — those that simultaneously address security and compliance requirements across multiple frameworks. Implementing these controls systematically will significantly reduce Botium Toys' risk exposure and bring the company into compliance with the regulations required to safely operate its growing online and EU-facing business.